

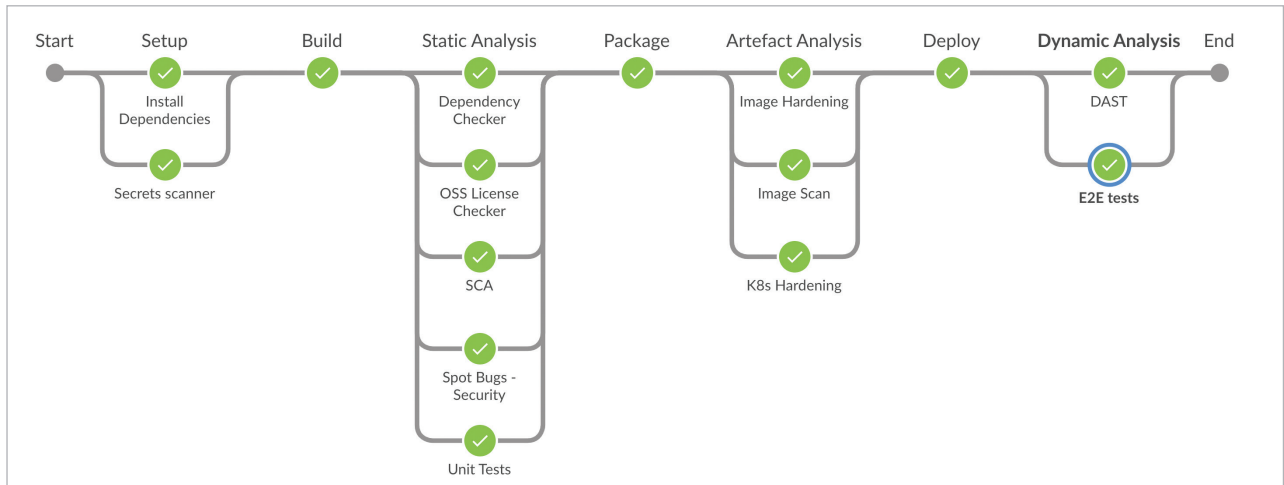


Figure 9: Sample secure pipeline (<https://github.com/rmkanda/secure-pipeline-java-demo>)

such as those listed below.

- Pipelines can help in identifying vulnerabilities, but what if the project is not under active development. How does one detect new vulnerabilities?
- Vulnerability may be fixed in a code, and reach the production environment.
- Admins may configure applications directly on the production environment. Who will be auditing those changes for misconfigurations that could lead to security issues?
- There might be PaaS tools used in the production environment. These tools won't be scanned as part of the pipeline. How does one audit such security configurations?

To avoid the above problems, we need to monitor applications from a security aspect as well. Again, this is quite a vast topic to cover.

One size doesn't fit all

Security should be contextual:

The above practices may need some tweaking considering your application's ecosystem and the team.

Security should be continuous:

Identify a strategy that fits for you. Retrospect often and improve it over time.

Security should be collaborative:

Security is everyone's job now. Collaborate with your delivery, infra and security teams.

Security is a journey, and not a destination: So let me end with my favourite quote: "The journey is what brings us happiness, not the destination," *Dan Millman, Way of the Peaceful Warrior.* **END** 🐧

References

- [1] <https://github.com/rmkanda/secure-pipeline-java-demo>
- [2] <https://www.informationisbeautiful.net/visualizations/worlds-biggest-data-breaches-hacks>
- [3] <https://nvd.nist.gov/general/visualizations/vulnerability-visualizations/cvss-severity-distribution-over-time>
- [4] <https://github.com/snyk/vulncost>
- [5] <https://github.com/anchore/grype-vscode>
- [6] <https://github.com/aquasecurity/trivy-vscode-extension>

By: Ramakrishnan Kandasamy

The author works at Thoughtworks Technologies, India. He is passionate about Application Security and Has good experience in scaling security practices across enterprises at scale aka DevSecOps.

THE COMPLETE MAGAZINE ON OPEN SOURCE

OpenSource
ForYou

The latest from the Open Source world is here.

OpenSourceForU.com

Join the community at facebook.com/opensourceforu

Follow us on Twitter @OpenSourceForU